Matriks Hak Akses KSMA per Peran dan Tindakan

Kitapandu School Management App

Versi 1.0 | 19 Oktober 2026 | Usulan untuk pembahasan pilot

Dokumen ini menetapkan usulan pembagian akses untuk pilot Vaneta Maju Berdaya. Tim produk, penanggung jawab lembaga dan tim pengembang dapat menggunakannya untuk menentukan siapa yang boleh melakukan suatu tindakan, pada data mana, dan dalam kondisi apa. Setiap izin harus memiliki batas lembaga, satuan, tugas atau hubungan peserta yang dapat diperiksa.

Rekomendasi utamanya adalah memberi izin berdasarkan pekerjaan yang perlu dilakukan. Jabatan pimpinan, pengelola akun maupun operator platform tidak otomatis membuka semua data. Hubungan wali akademik dan pembayar dipisahkan agar informasi pendidikan serta keuangan sampai kepada pihak yang tepat.

Dokumen ini memuat 73 tindakan usulan, 13 peran, aturan penggabungan peran, pengelolaan berkas, bantuan platform dan 24 skenario uji akses. Katalog mencakup seluruh 32 persyaratan fungsional pilot pada PRD. Daftar ini merupakan bahan implementasi dan penerimaan; belum memberikan izin nyata atau membuktikan sistem telah diuji.

Cara menggunakan dokumen

- Pimpinan Vaneta membahas kebutuhan jabatan nyata dan keputusan Q02 Q04 Q07 Q08 Q11 Q12 bersama penanggung jawab bidang.
- Tim produk mengubah hasil pembahasan menjadi profil izin bernama dan memiliki versi. Tim pengembang menerapkan pemeriksaan pada layanan, data, pekerjaan latar dan berkas.
- Penguji memakai skenario positif serta penolakan akses untuk membuktikan bahwa ruang lingkup setiap izin dipertahankan.

Cakupan produk

Pilot berfokus pada operasional kursus bahasa, caregiver, pemrograman, robotika dan AI. Struktur lembaga serta satuan mendukung perluasan ke sekolah, SLB, LK atau LKP, LPK dan PKBM. Aturan khusus kurikulum sekolah, program individual SLB dan layanan kesetaraan belum ditetapkan sebagai fitur pilot lengkap.

Dokumen pendamping: PRD v1.0, Blueprint Alur Pengguna v1.0, Arsitektur dan Model Data v1.0 serta Backlog MVP v1.0. Ketentuan operasional yang belum diputuskan tetap berstatus usulan.

1 Aturan keputusan akses

Usulan KSMA mengikuti prinsip hak minimum, penolakan bila tidak ada izin yang cocok, dan pemeriksaan pada setiap permintaan. OWASP menjelaskan prinsip tersebut serta perlunya mempertimbangkan atribut dan hubungan selain nama peran [R1]. Penerapannya pada KSMA dijabarkan sebagai rancangan produk berikut.

Syarat yang harus terpenuhi bersama

- Akun atau identitas layanan sah dan masih aktif. Konteks lembaga berasal dari sesi serta keanggotaan yang diverifikasi server.
- Ada grant aktif untuk tindakan yang diminta. Grant adalah catatan pemberian izin yang mencantumkan pemberi, penerima, tindakan, lingkup dan masa berlaku.
- Lembaga dan satuan objek berada dalam lingkup grant. Penugasan atau hubungan peserta yang diwajibkan juga aktif.
- Jenis kolom, klasifikasi berkas dan status objek mengizinkan tindakan tersebut. Rapor draf, misalnya, tidak menjadi dokumen portal.
- Pembatasan wajib dan kebijakan versi aktif terpenuhi. Izin yang tidak jelas atau konteks yang tidak tersedia menghasilkan penolakan.

Pengguna dengan beberapa peran

Evaluasi satu grant secara utuh. Sistem boleh mengizinkan permintaan jika ada grant yang memenuhi seluruh syaratnya; jangan mengambil tindakan dari grant A dan satuan atau peserta dari grant B. Pembatasan wajib seperti larangan lintas pelanggan, status draf di portal dan pencabutan aktif tetap berlaku.

Contoh: petugas memiliki FI di satuan A dan IN untuk kelas robotika di satuan B. Ia dapat mengelola transaksi satuan A serta sesi robotika B. Ia tidak dapat memverifikasi pembayaran B dengan menggabungkan kedua grant. Jika FI di B kemudian diberikan secara sah, tindakan finansial B baru dapat diizinkan melalui grant tersebut.

Makna kolom katalog

Kolom peran menunjukkan peran yang dapat diberi izin dalam profil usulan, bukan kewenangan yang pasti dimiliki semua pemegang jabatan. Tanda ! berarti tindakan harus disebut eksplisit dalam grant atau profil izin yang disetujui. Tanda ini tidak selalu mensyaratkan persetujuan manual untuk setiap klik.

Tindakan baca, perubahan, pengesahan, koreksi, unduh dan ekspor tetap berbeda. Hak melihat layar tidak cukup untuk memanggil API atau mengambil berkas. Tindakan yang belum tercantum ditolak sampai ditambahkan melalui perubahan kebijakan yang ditinjau.

2 Peran petugas lembaga

Peran berikut merupakan fungsi kerja yang diusulkan. Nama jabatan Vaneta dapat berbeda. Satu orang dapat memegang beberapa fungsi bila Q08 mengizinkan, dengan grant dan lingkup masing masing tetap terpisah.

Kode dan peran	Tugas utama	Batas bawaan
OW Pimpinan	Meninjau indikator dan menetapkan kebijakan dalam mandat	Tidak otomatis membaca bukti nilai, berkas pribadi, audit rinci atau membalik transaksi
AM Pengelola akses	Mengundang, memberi dan mencabut profil izin	Hanya dalam batas delegasi; tidak otomatis membaca isi peserta atau menyetujui peningkatan hak sendiri
AC Admin akademik	Pendaftaran, identitas peserta, kelas, jadwal dan permintaan akademik	Tidak otomatis memverifikasi uang, melihat bukti penilaian mentah atau menerbitkan rapor
FI Keuangan	Tagihan, pemeriksaan bukti, alokasi dan koreksi yang dimandatkan	Hanya identitas peserta yang perlu untuk transaksi; tanpa nilai atau catatan akademik internal
IN Pengajar	Sesi, presensi dan jurnal yang ditugaskan	Tidak otomatis menjadi penilai, pengesah, pengelola seluruh satuan atau pembaca seluruh riwayat peserta
AS Penilai	Komponen penilaian, peserta dan bukti dalam tugas	Tidak otomatis menerbitkan hasil, mengubah jadwal atau membaca catatan dukungan individual
AP Pengesah akademik	Memeriksa dan menerbitkan hasil serta kelulusan	Hanya program atau satuan mandat; tidak otomatis mengubah nilai sumber atau transaksi
AU Pemeriksa	Menelaah kejadian audit dan bukti pemeriksaan	Mandat baca tertentu; tanpa hak operasional tulis, isi semua berkas atau ekspor massal bawaan

Batas delegasi pengelolaan akses

AM memerlukan mandat tersendiri yang menyebut paket izin yang boleh diberikan, satuan, penerima yang memenuhi syarat dan batas waktunya. AM tidak harus memegang hak operasional yang didelegasikannya, tetapi tidak boleh melampaui batas delegasi. Perubahan mandat delegasi memerlukan pemberi kewenangan yang sah.

Pimpinan menetapkan pihak yang boleh menyetujui profil sensitif melalui Q08. OW tidak menjadi pengesah seluruh tindakan secara otomatis. Akun pemilik awal diaktifkan melalui onboarding yang terverifikasi; prosedur pengganti pengelola terakhir harus ditetapkan sebelum pilot.

3 Peran portal dan layanan platform

Kode dan peran	Hubungan atau mandat	Batas bawaan
ST Peserta	Akun terhubung ke profil peserta pada lembaga tertentu	Data diri dan layanan sendiri; tidak membaca peserta lain atau data yang belum diterbitkan
GU Wali akademik	Relasi akademik terverifikasi untuk peserta tertentu	Jadwal dan hasil terbit peserta terkait; hak finansial memerlukan relasi PY terpisah
PY Pembayar	Relasi finansial terverifikasi untuk kewajiban tertentu	Tagihan dan pembayaran dalam cakupan relasi; tidak mendapat presensi atau nilai
OP Operator platform	Konfigurasi layanan dan operasi teknis	Metadata layanan; isi pelanggan hanya melalui grant bantuan sementara yang disetujui
SV Identitas layanan teknis	Pekerjaan tertentu seperti audit, cadangan atau retensi	Identitas noninteraktif yang dibatasi tujuan, sasaran dan lingkungan; bukan akun admin umum

Lingkup yang dapat dicatat pada grant

Lembaga adalah batas pelanggan. Satuan adalah unit operasional di dalam pelanggan tersebut. Program, kelas, sesi, komponen penilaian dan kasus dukungan dapat mempersempit lingkup. Objek baru tidak otomatis masuk ke grant lama kecuali kebijakan grant memang mencakupnya secara eksplisit.

Relasi portal menghubungkan akun dengan profil peserta milik lembaga. Satu akun dapat memiliki beberapa relasi, tetapi setiap permintaan memilih peserta dan lembaga yang sesuai. Identitas peserta tidak digabung lintas lembaga hanya karena alamat email atau NIK sama.

Peserta dewasa tidak diwajibkan mempunyai wali. Seseorang yang membayar pelatihan peserta dewasa tetap hanya memperoleh akses sesuai relasi finansial. Untuk anak, perubahan wali, sengketa hubungan dan keputusan penerima informasi menunggu Q02; sistem tidak menyimpulkan kewenangan dari kesamaan nomor telepon atau nama keluarga.

Penugasan yang berubah

Grant pengajar menyebut kelas atau sesi serta tanggal efektif. Hak untuk meninjau riwayat setelah penugasan berakhir harus dinyatakan terpisah. Hak pengajar pengganti tidak otomatis mencakup semua kelas pengajar lama. Ketika peserta pindah satuan, riwayat lama tetap dimiliki lingkup asal; tujuan menerima data yang diperlukan melalui kewenangan yang disetujui.

4 Matriks pengelolaan platform

PLT01 sampai PLT04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
PLT-A01 Membuat pelanggan dan satuan	OP	Metadata layanan dan identitas satuan saja. Aktivasi pemilik melalui verifikasi onboarding; tanpa membaca isi peserta.
PLT-A02 Beralih konteks lembaga	OW AM AC FI IN AS AP ST GU PY AU	Keanggotaan atau relasi aktif pada lembaga tujuan. Pilihan konteks tidak memberi izin tambahan.
PLT-A03 Melihat profil dan merek	OW AM AC FI IN AS AP ST GU PY AU	Profil layanan yang disetujui tampil kepada pengguna; pengaturan internal hanya petugas berwenang.
PLT-A04 ! Mengubah profil dan merek	OW AM	Satuan yang dikelola; perubahan domain atau identitas penerbit perlu mandat khusus dan jejak perubahan.
PLT-A05 ! Mengundang dan mengubah izin	AM	Hanya paket izin dan satuan dalam mandat delegasi; dilarang menyetujui penambahan hak sendiri.
PLT-A06 ! Mencabut dan mengakhiri izin	AM	Dalam mandat pengelolaan; cegah hilangnya pemulih akses terakhir. Pencabutan berlaku pada permintaan berikutnya.
PLT-A07 ! Membaca jejak audit	AU	Jenis kejadian, satuan dan kolom audit yang ditugaskan; isi nilai atau bukti tidak otomatis terbuka.
PLT-A08 Mencatat jejak audit	SV	Hanya layanan penerbit kejadian yang sah, dengan identitas pelaku dan konteks. Tidak boleh mengubah atau menghapus jejak lama.

Pengaturan white label

Merek, domain dan fitur aktif merupakan konfigurasi pelanggan. Perubahan tersebut tidak mengubah pemilik data atau memperlebar lingkup izin. Pergantian nama pada antarmuka tidak boleh menyamarkan identitas petugas platform yang sedang menjalankan bantuan.

5 Matriks peserta dan pendaftaran

REG01 sampai REG04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
REG-A01 Melihat profil peserta	AC IN AS AP FI ST GU PY	AC sesuai satuan; IN AS AP sesuai tugas. ST diri sendiri; GU relasi akademik; FI PY hanya identitas minimum untuk pembayaran.
REG-A02 Membuat dan mengoreksi profil	AC	Dalam satuan tugas; pemeriksaan duplikasi. ST GU PY mengajukan koreksi melalui PRT-A05, bukan mengubah identitas terverifikasi langsung.
REG-A03 Melihat berkas pendaftaran	AC ST GU	AC menangani satuan tersebut; ST pendaftaran sendiri; GU hanya peserta yang sudah terhubung. Catatan internal hanya AC.
REG-A04 Memutuskan pendaftaran	AC	Keputusan dan alasan tercatat pada pendaftaran dalam satuan tugas. Bukan janji pembayaran terverifikasi atau kelulusan.
REG-A05 Melihat penempatan kelas	AC IN AS AP ST GU	Petugas sesuai satuan atau kelas tugas; portal hanya penempatan milik peserta terkait. Daftar peserta lain tidak tampil di portal.
REG-A06 Menetapkan penempatan	AC	Program, kelas dan satuan dalam mandat; kapasitas serta status pendaftaran valid. Tidak memintas daftar tunggu tanpa alasan tercatat.
REG-A07 Melihat riwayat perpindahan	AC ST GU	AC pada satuan terkait; ST GU hanya riwayat layanan peserta terkait tanpa catatan petugas terbatas.
REG-A08 ! Mengesahkan perpindahan	AC	Hak pada satuan asal dan tujuan harus diperiksa terpisah. Jika berbeda petugas, gunakan persetujuan asal serta tujuan.
REG-A09 Membuat dan melanjutkan draf	AC	Pendaftaran pada satuan tugas; simpan draf tanpa mengaktifkan peserta di kelas. Formulir mandiri hanya ditambah bila kebutuhan pilot disetujui.

Pembatasan pencarian

Pencarian duplikasi, saran nama, jumlah hasil dan pelengkapan otomatis mengikuti lingkup yang sama dengan data utama. Petugas satuan tidak boleh mengetahui keberadaan profil pelanggan lain dari pesan duplikasi. Proses penggabungan profil di luar alur koreksi biasa memerlukan aturan tersendiri sebelum diaktifkan.

6 Matriks program kelas dan jadwal

CLS01 sampai CLS04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
CLS-A01 Melihat versi program	AC IN AS AP ST GU	Petugas sesuai mandat; ST GU versi program yang diikuti. Rubrik internal dan draf belum terbit tidak ikut terbuka.
CLS-A02 Membuat dan menerbitkan program	AC	Satuan dan program yang dikelola; versi lama tetap terlacak. Hak program tidak otomatis memberi hak terbit rapor.
CLS-A03 Melihat kelas dan kapasitas	AC IN AS AP	AC pada satuan; petugas lain hanya kelas tugas. Kontak peserta mengikuti REG-A01, bukan seluruh daftar identitas.
CLS-A04 Membuat kelas dan kapasitas	AC	Satuan tugas; penetapan pengajar mensyaratkan penugasan sah, bukan otomatis memberi hak pengelolaan akses.
CLS-A05 Melihat jadwal sesi	AC IN AS AP ST GU	Petugas sesuai penugasan; ST GU jadwal peserta terkait. Pembayar tanpa relasi akademik tidak mendapat jadwal.
CLS-A06 Membuat dan mengubah jadwal	AC	Satuan tugas dan pemeriksaan benturan. Hasil pemeriksaan lintas satuan cukup status benturan, tanpa membocorkan rincian yang tak berhak.
CLS-A07 Mengajukan perubahan sesi	IN ST GU	IN sesi tugas; ST GU peserta terkait. Permintaan tidak langsung membatalkan sesi atau mengubah saldo hak pertemuan.
CLS-A08 Memutuskan jadwal pengganti	AC	Sesi dalam satuan tugas; alasan dan notifikasi penerima sah. Aturan pembatalan serta kredit menunggu Q05.

Konflik yang melintasi lingkup

Pemeriksaan ketersediaan pengajar atau ruang boleh mengembalikan status tersedia atau bentrok tanpa membuka judul program, peserta dan catatan dari satuan yang tidak dapat dilihat pengguna. Keputusan pemindahan tetap ditangani pihak yang berwenang atas sesi sumber.

7 Matriks pelaksanaan pembelajaran

SES01 sampai SES04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
SES-A01 Melihat presensi	AC IN AS AP ST GU	Petugas sesuai satuan atau tugas; ST GU hanya presensi peserta terkait. Daftar teman sekelas tidak disajikan.
SES-A02 Mencatat presensi	IN	Hanya sesi penugasan aktif, daftar peserta sesi sah dan status masih dapat diedit. Penugasan pengganti mengikuti SES-A08.
SES-A03 Melihat jurnal sesi	AC IN AS AP ST GU	Petugas sesuai tugas; portal hanya ringkasan yang dinyatakan untuk peserta. Catatan internal atau dukungan individual tidak ikut terbaca.
SES-A04 Menulis jurnal sesi	IN	Sesi tugas yang masih terbuka. Tandai bagian internal dan ringkasan portal secara eksplisit; pengambilan berkas melalui X-A01.
SES-A05 Menutup sesi	IN	Sesi tugas; kelengkapan presensi dan jurnal sesuai Q06. Penutupan tidak otomatis memotong hak pertemuan sebelum aturan Q05 disahkan.
SES-A06 ! Mengoreksi sesi tertutup	AC IN	Mandat koreksi eksplisit per satuan atau sesi, alasan dan versi sebelum sesudah wajib. Catatan lama tetap terlacak.
SES-A07 Melihat penugasan pengganti	AC IN	AC pada satuan; IN penugasan dirinya. Daftar penugasan lain hanya untuk petugas yang perlu mengatur jadwal.
SES-A08 ! Menetapkan pengajar pengganti	AC	Sesi, rentang waktu dan peserta yang perlu ditangani ditetapkan. Hak pengajar lama berakhir sesuai tanggal efektif; tidak ada akses riwayat tanpa batas.

Koreksi sesudah sesi ditutup

Usulan awal membedakan pencatatan harian dari izin koreksi setelah penutupan. Q06 menetapkan status, batas waktu dan alasan yang wajib; Q08 menentukan pihak yang boleh mengoreksi atau mengesahkan. Sistem menyimpan versi dan pelaku sehingga koreksi tetap dapat ditelusuri.

8 Matriks penilaian dan hasil belajar

ASM01 sampai ASM04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
ASM-A01 Melihat rubrik penilaian	AC IN AS AP	Program atau kelas tugas. Portal memakai hasil terbit; rincian rubrik hanya bila kebijakan publikasi program mengizinkan.
ASM-A02 ! Membuat versi rubrik	AC AS	AC program kelolaan; AS hanya dengan mandat penyusun. Versi yang sudah dipakai tidak ditimpa.
ASM-A03 Membaca draf dan bukti nilai	IN AS AP	Hanya peserta dan komponen penilaian yang ditugaskan; jurnal internal atau data dukungan tidak diwariskan. Berkas perlu X-A01.
ASM-A04 Mencatat dan merevisi nilai	AS	Komponen, peserta dan versi rubrik tugas. IN membutuhkan peran AS untuk menilai; revisi setelah terbit melalui alur versi baru.
ASM-A05 Melihat rapor terbit	ST GU IN AS AP AC	ST GU peserta terkait; petugas sesuai mandat. AC hanya dokumen terbit untuk administrasi, bukan otomatis bukti penilaian mentah.
ASM-A06 ! Menerbitkan dan mengganti rapor	AP	Mandat program atau satuan dan versi yang diajukan. Draf lama serta alasan penggantian terlacak; kombinasi AS AP menunggu Q08.
ASM-A07 Melihat kelulusan dan sertifikat	ST GU AC IN AS AP	Peserta terkait atau tugas yang sah. Sertifikat internal tidak dinyatakan sebagai sertifikasi kompetensi eksternal.
ASM-A08 ! Mengesahkan dan mencabut sertifikat	AP	Mandat penerbit, aturan Q07 Q12 dan alasan pencabutan. Verifikasi publik belum aktif sebelum kebijakan data disepakati.

Pemisahan penilai dan pengesah

IN yang melakukan penilaian harus memiliki grant AS yang sesuai. AS yang juga menjadi AP tidak dilarang secara menyeluruh oleh dokumen ini; kombinasi itu menunggu keputusan Q08. Bila lembaga mensyaratkan orang berbeda, pemeriksaan harus membandingkan identitas akun pelaku, bukan hanya nama peran.

9 Matriks keuangan

FIN01 sampai FIN04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
FIN-A01 Melihat tagihan dan cicilan	FI ST PY	FI satuan tugas; ST tagihan dirinya; PY kewajiban yang tercakup relasi finansial. GU perlu relasi PY terpisah.
FIN-A02 Membuat dan menerbitkan tagihan	FI	Satuan tugas dan aturan biaya yang disahkan. Diskon di luar kebijakan perlu mandat X-A06. Tidak mengunci akses akademik otomatis.
FIN-A03 Mengajukan bukti pembayaran	FI ST PY	FI pada satuan tugas; ST PY tagihan diri atau relasi finansial yang sah. Bukti masuk sebagai diajukan; saldo invoice belum berubah.
FIN-A04 ! Memverifikasi atau menolak bukti	FI	Satuan tugas, bukti dan referensi pembayaran yang diperiksa. Alasan keputusan dicatat. Verifikasi belum berarti alokasi.
FIN-A05 Mengalokasikan pembayaran	FI	Pembayaran terverifikasi dan tagihan pada tenant yang sama; peserta atau kewajiban sesuai kebijakan Q04. Batas saldo diperiksa secara atomik.
FIN-A06 Melihat kuitansi dan alokasi	FI ST PY	FI satuan tugas; portal hanya pembayaran dan alokasi dalam hak finansialnya. Kuitansi tidak memberi akses nilai peserta.
FIN-A07 Mengajukan koreksi keuangan	FI ST PY	FI transaksi tugas; ST PY transaksi terkait. Pengajuan tidak menghapus tagihan, alokasi atau pembayaran terverifikasi.
FIN-A08 ! Mengesahkan pembalikan transaksi	FI	Mandat koreksi eksplisit, alasan dan referensi transaksi asal. Tetap simpan audit; pemisahan pembuat serta pengesah mengikuti Q04 Q08.

Pembayaran dan akses akademik

Status unggahan bukti, pembayaran terverifikasi, alokasi ke tagihan, sisa tagihan dan keterlambatan merupakan keadaan berbeda. Izin keuangan tidak mengizinkan perubahan nilai. Tunggakan juga tidak otomatis menutup portal akademik sampai ada kebijakan yang disetujui melalui Q04 dan perubahan kebutuhan yang ditinjau.

10 Matriks portal dan komunikasi

PRT01 sampai PRT04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
PRT-A01 Membuka portal akademik	ST GU	ST diri sendiri; GU relasi akademik terverifikasi dan aktif. Hanya jadwal, ringkasan presensi dan hasil yang telah terbit.
PRT-A02 Membuka portal keuangan	ST PY	ST diri sendiri; PY kewajiban dalam relasi finansial aktif. Wali tanpa relasi pembayar tidak mendapat hak otomatis.
PRT-A03 Melihat relasi peserta	AC ST GU PY	AC petugas verifikasi; ST relasinya sendiri; GU PY hanya relasi sendiri dan status yang relevan. Identitas wali lain tidak otomatis terbuka.
PRT-A04 ! Memverifikasi atau mencabut relasi	AC	Mandat verifikasi, bukti minimum, jenis akademik atau finansial dan tanggal efektif. Permintaan pihak terkait perlu diperiksa.
PRT-A05 Mengajukan permintaan layanan	ST GU PY IN	Objek yang berhak diakses dan kategori sesuai hubungan. PY hanya urusan finansial; IN hanya sesi tugas.
PRT-A06 Menangani permintaan dan notifikasi	AC FI	AC kategori akademik; FI kategori finansial. Hak menangani tiket tidak memberi hak eksekusi koreksi yang memerlukan izin lain.
PRT-A07 Mengubah preferensi komunikasi	ST GU PY	Preferensi akun sendiri dalam relasi aktif. Tidak bisa mendaftarkan penerima lain atau mengaktifkan otomatisasi kanal yang belum tersedia.
PRT-A08 ! Membuat pesan manual dan daftar penerima	AC FI	AC topik akademik; FI topik finansial. Pratinjau penerima sesuai relasi aktif; keluaran massal memerlukan OPS-A04.

Penerima notifikasi

Hak penerima diperiksa kembali ketika notifikasi dibuat dan saat informasi dibuka. Notifikasi pada perangkat bersama sebaiknya memuat pesan minimum serta tautan ke portal. Antrean pesan tidak boleh mempertahankan penerima yang relasinya sudah dicabut. Pilot menggunakan notifikasi internal dan templat manual; otomatisasi WhatsApp, SMS dan email bukan janji tahap ini.

11 Matriks data dan operasi

OPS01 sampai OPS04 | Semua baris berstatus usulan | ! memerlukan izin eksplisit

Tindakan	Peran	Kondisi dan batas
OPS-A01 Meninjau dan memetakan impor	AC FI	AC dataset akademik; FI dataset finansial. Hanya kolom dan satuan yang diizinkan; baris tidak sah ditolak pada pratinjau.
OPS-A02 ! Mengomit impor data	AC FI	Pemeriksaan ulang izin per baris saat komit, versi pemetaan dan ringkasan rekonsiliasi. Impor tidak memintas izin koreksi.
OPS-A03 Melihat pratinjau ekspor	AC FI AU OW	Satuan dan kolom dari izin baca yang dimiliki; OW hanya ringkasan atau dataset yang dimandatkan. Data sensitif tetap dipangkas.
OPS-A04 ! Membuat dan mengambil ekspor	AC FI AU OW	Izin ekspor eksplisit, dataset dan kolom yang sah; cek ulang saat menghasilkan serta mengambil berkas. Tidak ada ekspor semua data bawaan.
OPS-A05 Memantau pekerjaan cadangan	OP OW AU	OP metadata teknis tanpa isi cadangan; OW status lembaga sendiri; AU bukti pemeriksaan dalam mandat. Akses isi cadangan melalui X-A05.
OPS-A06 Menjalankan pekerjaan cadangan	SV	Identitas layanan khusus, penyimpanan dan kunci dalam lingkup operasi. Bukan hak mengunduh cadangan ke akun petugas.
OPS-A07 Melihat indikator dan antrean	OW AC FI IN AS AP AU	OW agregat satuan; petugas antrean sesuai tugas. Telusur ke rincian memakai izin objek asal, bukan hak dashboard saja.
OPS-A08 Mengubah filter indikator pribadi	OW AC FI IN AS AP AU	Preferensi tampilan milik sendiri; filter tidak dapat memperluas data. Definisi metrik bersama hanya dengan mandat X-A08.

Ekspor sebagai tindakan terpisah

Hak baca layar tidak otomatis mengizinkan salinan massal. Ekspor menyebut tujuan, dataset, satuan dan kolom; filter yang dikirim pengguna tidak menjadi batas keamanan. Berkas hasil ekspor tetap privat, memiliki masa berlaku yang ditetapkan dan meninggalkan catatan pembuatan serta pengambilan.

12 Izin lintas modul yang dibatasi

Kode X melengkapi aturan fitur, bukan menambah delapan persyaratan fungsional baru pada PRD. Izin X tidak dapat menggantikan hak atas objek sumber.

Tindakan	Peran	Kondisi dan batas
X-A01 ! Membuka dan mengunduh berkas privat	AC FI IN AS AP ST GU PY AU	Izin berkas dan baca objek induk sama sama sah, kelas berkas dan versi sesuai. Server memeriksa ulang sebelum mengirim berkas.
X-A02 ! Mengakses data dukungan individual	IN AP	Mandat kasus, peserta, tujuan dan waktu berlaku eksplisit. Hanya kebutuhan akomodasi yang perlu diketahui; diagnosis tidak diwajibkan.
X-A03 ! Menyetujui bantuan platform	AM	Persetujuan pihak yang berwenang atas data, tiket, tindakan, objek, penyamaran kolom dan kedaluwarsa. Tidak boleh menyetujui perluasan hak sendiri.
X-A04 ! Menjalankan bantuan platform	OP	Grant bantuan X-A03 aktif, tindakan asal tetap diperiksa. Sesi bantuan berlabel dan diaudit; tanpa pengambilalihan sandi pengguna.
X-A05 ! Mengotorisasi pemulihan	OP OW	Permintaan OW yang memiliki mandat pemulihan lembaga serta persetujuan OP yang memiliki mandat teknis; eksekusi SV terikat pekerjaan dan lingkungan sasaran.
X-A06 ! Mengesahkan pengecualian biaya	OW FI	Mandat batas nominal dan satuan eksplisit menurut Q04. Grant ini tidak memberi hak verifikasi, pembalikan, atau perubahan nilai akademik.
X-A07 ! Mengeksekusi retensi dan penghapusan	SV	Hanya pekerjaan disahkan penanggung jawab data, objek dan dasar kebijakan Q11. Tahan proses saat ada penahanan; bukti pelaksanaan terpisah.
X-A08 ! Mengubah definisi indikator	OW	Mandat definisi bersama dan versi metrik; penelusuran data serta ekspor tetap memerlukan haknya sendiri.

Izin gabungan untuk berkas

Pengambilan berkas membutuhkan X-A01 dan izin baca objek induk yang sama sama valid pada saat pengambilan. Profil ST, misalnya, dapat secara eksplisit memuat X-A01 untuk rapor terbit miliknya; tidak perlu persetujuan petugas setiap kali mengunduh. Grant tersebut tidak berlaku pada bukti penilaian mentah atau bukti pembayaran orang lain.

13 Batas kolom dan dokumen

Matriks tindakan harus diterapkan juga pada kolom respons, hasil pencarian, cetakan dan berkas. Data yang tidak boleh dilihat tidak dikirim ke peramban untuk sekadar disembunyikan oleh tampilan.

Kelompok data	Akses yang diusulkan	Pembatasan keluaran
Identitas dan kontak	AC untuk administrasi; petugas tugas dan portal sesuai kebutuhan	FI dan PY cukup nama, nomor peserta serta kontak finansial yang sah; tanpa seluruh berkas pendaftaran
Presensi dan jurnal	IN pada sesi tugas; AC sesuai satuan; ST GU bagian yang diterbitkan	Pisahkan catatan internal dari ringkasan portal; tidak tampilkan peserta lain
Draf nilai dan bukti	IN AS AP sesuai penugasan dan fungsi	AC mendapat rapor terbit untuk administrasi; FI PY dan OW tanpa mandat akademik tidak mendapat nilai
Rapor dan sertifikat terbit	ST GU serta petugas sesuai matriks ASM	Versi terbit, status pencabutan dan pihak penerbit jelas; unduh tetap perlu X-A01
Tagihan dan bukti uang	FI serta ST PY sesuai relasi dan transaksi	Bukti rekening dapat mengandung identitas pihak lain; jangan menyalin seluruh bukti ke notifikasi
Dukungan individual	IN AP dengan X-A02 dan mandat kasus	Catatan kebutuhan akomodasi minimum; tidak mewajibkan diagnosis atau membuka semua catatan kesehatan
Audit dan log teknis	AU sesuai mandat; OP metadata teknis	Hindari sandi, token dan isi berkas pada log; tampilkan identitas objek secukupnya

Publikasi dan berbagi

Unduhan rapor pribadi dan ekspor massal berbeda. Tautan sertifikat publik merupakan kebijakan terpisah yang menunggu Q12, termasuk data yang dapat ditampilkan dan cara pencabutannya. Sampai keputusan itu ada, dokumen peserta tetap privat. Tidak tersedia direktori publik peserta dalam pilot.

Izin cetak atau unduh membatasi pengambilan melalui sistem. Salinan yang telah disimpan pengguna tidak dapat ditarik kembali secara teknis; pencabutan menghentikan akses berikutnya di KSMA. Kebijakan penyimpanan serta pengiriman salinan perlu dijelaskan dalam panduan pengguna.

14 Pemberian perubahan dan pencabutan izin

Catatan minimum sebuah grant

Kelompok	Nilai yang harus tercatat
Identitas	ID grant, akun atau identitas layanan penerima, lembaga dan jenis grant
Lingkup	Satuan, tindakan, kelas atau sesi bila perlu, peserta atau kasus dan kolom yang diizinkan
Landasan	Pemberi, kewenangan pemberi, alasan atau tiket, versi profil serta kebijakan
Waktu	Mulai berlaku, akhir berlaku bila relevan, status aktif, waktu dan alasan pencabutan
Kendali	Batas delegasi, syarat persetujuan, pembatasan tambahan dan versi untuk pembatalan cache

Alur yang diusulkan

- Ajukan kebutuhan fungsi beserta lingkup dan masa berlaku. Permintaan tidak langsung menjadi izin aktif.
- Pemberi yang memiliki mandat memeriksa kebutuhan serta kombinasi peran. Hak khusus dan delegasi harus disebut eksplisit.
- AM menerapkan profil versi yang disetujui. Penerima mengetahui lembaga, satuan dan fungsi yang diberikan.
- Ketika jabatan, penugasan atau relasi berubah, akhiri grant lama dan catat perubahan. Tinjauan berkala memakai interval yang disepakati pada Q08.
- Pencabutan memperbarui versi otorisasi, sesi yang relevan, antrean pekerjaan, akses berkas dan cache. Permintaan berikutnya harus memakai keadaan izin terbaru.

Pemeriksaan ulang yang wajib dirancang

Pemeriksaan dilakukan ketika pekerjaan dijadwalkan, saat dieksekusi dan sebelum hasil diserahkan kepada pengguna. Perubahan izin setelah pekerjaan dimulai dapat membatalkan pengambilan hasil. Pada transaksi tulis, periksa kembali izin dan status objek sebelum komit bila terjadi perubahan bersamaan.

Respons idempoten yang disimpan tidak boleh mengembalikan data setelah izin dicabut. Otorisasi saat ini diperiksa sebelum respons lama diberikan. Impor juga harus memeriksa setiap baris dan kolom, bukan menganggap izin unggah sebagai izin menjalankan semua tindakan di dalam berkas.

Penghentian pengguna dan pemulihan akses

Nonaktifkan akun atau keanggotaan tanpa menghapus atribusi pelaku di riwayat. Pengguna yang kehilangan pengelola terakhir mengikuti proses pemulihan terverifikasi. Operator platform tidak boleh membuat grant pemilik hanya berdasarkan permintaan email yang belum diperiksa. Bukti dan pihak pengesah proses ini menunggu Q08.

15 Bantuan platform berkas dan pemulihan

Bantuan dengan izin sementara

OP dapat memantau status layanan tanpa membuka isi pelanggan. Jika masalah memerlukan isi data, petugas berwenang pada lembaga menyetujui X-A03. Persetujuan menyebut tiket, pelaku platform, lembaga, objek atau dataset, tindakan, kolom yang perlu disamarkan dan waktu berakhir. Hak menulis atau ekspor tidak boleh tersirat dari izin membaca.

Sesi X-A04 mencatat identitas operator sebenarnya dan grant bantuan. Semua tindakan yang dijalankan harus berada dalam katalog yang disetujui grant tersebut. Grant bantuan tidak melewati larangan wajib, tidak dapat diperluas sendiri dan berakhir saat dicabut atau kedaluwarsa. Akses darurat tetap memerlukan jalur persetujuan yang ditetapkan sebelumnya pada Q08.

Jalur pengambilan berkas

Usulan arsitektur menggunakan berkas privat dan pengambilan melalui server yang memeriksa izin aktif sebelum mengirim hasil. Pemeriksaan mencakup pemilik objek, versi, klasifikasi berkas dan hak unduh. Nama berkas, alamat penyimpanan atau ID acak bukan pengganti pemeriksaan izin.

Tautan langsung bertanda tangan yang masih berlaku tidak selalu dapat dicabut segera. Karena itu, jalur tersebut tidak boleh dipakai untuk menjanjikan pencabutan pada permintaan berikutnya tanpa mekanisme tambahan yang dibuktikan. Rincian teknologi ditetapkan dalam spesifikasi implementasi.

Cadangan dan pemulihan

SV menjalankan cadangan sesuai pekerjaan, sasaran dan lingkungan. Hak aplikasi pengguna tidak berarti hak membaca arsip cadangan. Usulan X-A05 memerlukan permintaan pemegang mandat lembaga dan persetujuan operator dengan mandat teknis; eksekusi memakai identitas layanan terbatas serta lingkungan yang dinyatakan.

Jika cadangan fisik berisi beberapa pelanggan, pemulihan satu lembaga tidak boleh langsung mengembalikan seluruh basis data ke produksi bersama. Gunakan prosedur pemulihan terisolasi dan rekonsiliasi lingkup yang disetujui. Rincian ini harus dibuktikan pada uji pemulihan sebelum klaim layanan dibuat.

Batas operasi teknis

Administrator infrastruktur mungkin memerlukan kemampuan teknis di luar aplikasi. Kemampuan itu dicatat dan dikelola sebagai akses infrastruktur tersendiri, dengan kredensial, jejak dan prosedur yang sesuai. Dokumen ini tidak mengklaim bahwa matriks aplikasi saja meniadakan kemampuan administrator infrastruktur.

16 Skenario uji fungsi dan pembatasan

Semua skenario berikut berstatus direncanakan. Setiap uji mencatat akun uji, grant, lembaga, satuan, objek, versi kebijakan, permintaan, keputusan dan keluaran yang terlihat. Gunakan data sintetis. Uji penolakan harus memeriksa respons dan efek samping, bukan hanya hilangnya tombol.

Uji dan izin	Permintaan uji	Hasil yang diharapkan
T01 PLT-A02 REG-A01	AC lembaga A meminta profil lembaga B melalui ID langsung.	Tolak tanpa data, jumlah hasil atau efek samping; AC tetap bisa membaca profil yang diizinkan di A.
T02 PLT-A02 FIN-A04 SES-A02	FI di satuan A dan IN di B mencoba verifikasi pembayaran B.	Tolak verifikasi B; izinkan sesi tugas B. Jangan menggabungkan tindakan FI dengan lingkup IN.
T03 PRT-A01 PRT-A02	GU tanpa relasi PY membuka rapor terbit lalu invoice peserta terkait.	Rapor boleh; invoice ditolak. PY tanpa GU mendapat hasil kebalikan untuk ruang akademik.
T04 PRT-A01 REG-A05	GU dua peserta beralih pilihan anak dan memanggil ID anak yang tidak terhubung.	Dua peserta sah dapat dipilih; peserta ketiga dan daftar teman kelas ditolak.
T05 FIN-A01 PRT-A02	ST dewasa tanpa GU membaca tagihan sendiri; sponsor PY meminta nilai peserta itu.	ST boleh mengakses miliknya; sponsor hanya kewajiban finansial sesuai relasi, nilai ditolak.
T06 SES-A02 ASM-A04 ASM-A06	IN dengan sesi aktif mencoba mencatat presensi, menulis nilai dan menerbitkan rapor.	Presensi boleh; nilai perlu AS; terbit perlu AP eksplisit. Penugasan sesi saja tidak cukup.
T07 SES-A08 SES-A03	Pengajar pengganti membaca sesi pengganti dan riwayat seluruh kelas pengajar lama.	Hanya sesi dan riwayat yang dinyatakan dalam penugasan boleh; bagian lain ditolak.
T08 ASM-A03 ASM-A05	ST meminta rapor draf; AC meminta bukti penilaian mentah tanpa grant penilaian.	Keduanya ditolak; rapor terbit milik ST dan salinan administrasi sah milik AC boleh.
T09 ASM-A06 FIN-A08	Akun pembuat juga pengesah, diuji pada dua versi kebijakan kombinasi peran.	Jika kombinasi disetujui, izin berlaku sesuai grant; jika wajib orang berbeda, identitas akun yang sama ditolak.
T10 FIN-A03 FIN-A04 FIN-A05	PY mengunggah bukti; FI memverifikasi, lalu mengalokasikan dana.	Unggahan belum mengubah saldo; verifikasi belum alokasi; perubahan saldo hanya setelah alokasi sah.
T11 X-A02 REG-A01	FI dan IN tanpa mandat kasus mencoba membaca catatan dukungan individual.	Keduanya ditolak; IN dengan X-A02 kasus terkait mendapat bagian minimum yang diizinkan.
T12 OPS-A07 OPS-A04	OW melihat agregat lalu mencoba membuka bukti uang, nilai dan ekspor semua data.	Agregat boleh; rincian dan ekspor memerlukan grant tersendiri yang cocok, selain itu ditolak.

Keluaran yang tidak membocorkan data

Respons penolakan mengikuti aturan aplikasi tanpa mengungkap nama peserta, jumlah hasil, lampiran atau keberadaan objek yang tidak berhak diketahui. Log pemeriksaan cukup membantu diagnosis dan penelusuran tanpa menyalin isi sensitif. Detail kode respons dan pesan pengguna ditetapkan pada spesifikasi API.

17 Skenario pencabutan dan operasi

Pengujian lintas antarmuka mencakup API langsung, pencarian, pratinjau, pekerjaan latar, pengambilan hasil dan berkas. Hasil yang diharapkan di bawah merupakan syarat rancangan; belum menjadi hasil uji perangkat lunak.

Uji dan izin	Permintaan uji	Hasil yang diharapkan
T13 PLT-A06 X-A01	Cabut grant setelah halaman terbuka; ulangi API dan unduh berkas dari tautan lama.	Permintaan berikutnya ditolak; cache, sesi dan jalur berkas tidak memulihkan hak lama.
T14 OPS-A04 PLT-A06	Cabut izin ekspor setelah pekerjaan diantrekan atau ketika hasil sudah dibuat.	Eksekusi atau pengambilan hasil ditolak sesuai waktu pencabutan; tidak ada berkas di luar izin.
T15 PRT-A04 PRT-A06	Akhiri relasi GU atau PY sebelum notifikasi diproses dan tautan dibuka.	Penerima tidak lagi diproses sebagai relasi aktif; tautan tidak membuka informasi yang sudah tidak berhak.
T16 X-A03 X-A04	OP tanpa grant bantuan meminta isi pelanggan; ulangi dengan grant aktif lalu kedaluwarsa.	Awal ditolak; aktif hanya objek serta tindakan yang disetujui; setelah berakhir ditolak dan seluruh kegiatan terlacak.
T17 OPS-A02 REG-A08	Impor memuat baris lintas satuan atau kolom di luar izin; pindahkan peserta tanpa mandat tujuan.	Baris tidak sah ditolak dan tidak terkomit; perpindahan menunggu kewenangan asal serta tujuan.
T18 FIN-A08 PLT-A06	Kirim ulang kunci idempoten setelah hak koreksi dicabut; ubah izin saat transaksi belum komit.	Tidak mengembalikan data lama atau efek baru tanpa izin kini; pemeriksaan komit menghentikan perubahan yang tidak sah.
T19 OPS-A06 X-A05	Pulihkan satu lembaga dari cadangan beberapa pelanggan memakai pekerjaan terbatas.	Lingkungan terisolasi, mandat valid dan rekonsiliasi lingkup dibuktikan; data pelanggan lain tidak masuk ke layanan sasaran.
T20 PLT-A05 PLT-A07	AM mencoba memberi hak khusus pada diri sendiri; AU mencoba mengubah audit.	Keduanya ditolak; perubahan sah oleh pemberi mandat berbeda dan pembacaan AU tetap dapat ditelusuri.
T21 SES-A02 SES-A06 ASM-A06	Dua petugas mengubah versi sama; yang lain mencabut penugasan atau menerbitkan objek lebih dulu.	Permintaan memakai keadaan lama tidak menimpa hasil; versi, status dan grant diperiksa ulang sebelum perubahan.
T22 X-A01 X-A07	Minta berkas dengan URL penyimpanan langsung lalu jalankan retensi tanpa kebijakan disahkan.	Berkas privat tidak terbuka; retensi tanpa mandat ditolak; audit tidak kehilangan atribusi dan referensi yang wajib dipertahankan.
T23 CLS-A06 REG-A01 OPS-A03	Cari nama, pratinjau ekspor atau konflik jadwal yang menyentuh objek di luar lingkup.	Tidak bocor nama, jumlah, lampiran atau isi konflik; hanya keluaran minimum yang memang diizinkan.
T24 PLT-A05 OPS-A06 X-A05	Akun manusia mencoba memakai identitas cadangan; SV mencoba sesi portal dan pekerjaan tenant lain.	Keduanya ditolak; SV hanya pekerjaan tujuan sah dan sasaran yang dimandatkan, bukan login interaktif umum.

18 Ketertelusuran kebutuhan dan backlog

Pada tiap modul, A01 dan A02 dipetakan ke kebutuhan 01, A03 dan A04 ke 02, A05 dan A06 ke 03, serta A07 dan A08 ke 04. REG-A09 juga mendukung REG02. Pemetaan lengkap per tindakan tersedia dalam register terstruktur.

Kebutuhan PRD	Tindakan katalog	Paket backlog
PLT01 sampai PLT04	PLT-A01 sampai A08	BL01 sampai BL04
REG01 sampai REG04	REG-A01 sampai A08 serta A09	BL05 sampai BL08
CLS01 sampai CLS04	CLS-A01 sampai A08	BL09 sampai BL12
SES01 sampai SES04	SES-A01 sampai A08	BL13 sampai BL16
ASM01 sampai ASM04	ASM-A01 sampai A08	BL17 sampai BL20
FIN01 sampai FIN04	FIN-A01 sampai A08	BL21 sampai BL24
PRT01 sampai PRT04	PRT-A01 sampai A08	BL25 sampai BL28
OPS01 sampai OPS04	OPS-A01 sampai A08	BL29 sampai BL32

Kebutuhan mutu yang terkait langsung

NFR01 menjadi dasar pemeriksaan lingkup; NFR02 menyangkut akun dan sesi; NFR06 terkait transaksi serta respons idempoten; NFR07 terkait berkas; NFR08 terkait kesalahan dan log; NFR09 terkait cadangan serta pemulihan. NFR03 NFR04 NFR05 dan NFR10 tetap diuji pada rencana mutu umum, bukan dinyatakan terpenuhi oleh matriks ini.

U01 sampai U32 menjadi acuan alur fungsional. U33 dan U36 terkait langsung dengan pencabutan serta penanganan kegagalan atau dukungan. U34 dan U35 tetap menguji aksesibilitas serta kinerja pada rencana penerimaan umum. Paket BL01 sampai BL32 mempertahankan urutan persyaratan pada backlog, tanpa mengubah statusnya sebagai usulan.

Sumber terstruktur permission_register.json menyimpan tindakan dan kondisi; traceability.json menyimpan cakupan serta skenario. Konsistensi referensi diperiksa saat dokumen dibuat. Pemeriksaan ini hanya memvalidasi artefak dokumen.

Syarat selesai implementasi akses

Setiap tindakan harus dipetakan ke layanan dan pemeriksaan data. Jalankan seluruh skenario yang berlaku setelah implementasi, tutup keputusan yang memengaruhi izin, lalu hubungkan bukti ke UAT PRD. Setelah izin berubah, uji ulang grant tunggal, kombinasi peran dan batas pelanggan yang terdampak. Temuan akses di luar izin harus diperbaiki dan diuji ulang sebelum rilis pilot.

19 Keputusan yang perlu ditetapkan untuk pilot

Rujukan	Keputusan pemilik proses	Dampak terhadap izin
Q01 Q08	Identitas lembaga, satuan, pemilik awal, pemberi mandat dan pemulihan akun	Menetapkan batas pelanggan, delegasi dan pengesah akses yang sah
Q02	Kelompok usia, bukti hubungan, perubahan wali, pembayar dan pencabutan	Menentukan aktivasi serta penghentian relasi portal
Q03 Q05	Penempatan, perpindahan, jeda, pengganti dan hak pertemuan	Menentukan objek yang boleh diubah serta efeknya pada layanan
Q04	Batas diskon, verifikasi, koreksi, pengembalian dan penanganan tunggakan	Menentukan grant FI khusus dan pengesah pengecualian
Q06 Q07	Penutupan sesi, koreksi, rubrik, kelulusan dan pengesah hasil	Menentukan status yang dapat diedit dan mandat AS AP
Q08	Kombinasi peran, pembuat serta pengesah, tinjauan hak, autentikasi dan bantuan	Menentukan pemisahan tugas yang benar benar berlaku pada Vaneta
Q09 Q10	Penerima pesan, templat manual, sumber impor dan penanggung jawab data	Menentukan hak komunikasi, kolom impor dan bukti rekonsiliasi
Q11	Penyimpanan berkas, retensi, penghapusan, cadangan dan pemulihan	Menentukan masa berlaku hasil, pekerjaan SV dan prosedur X-A05 X-A07
Q12 Q13	Penerbit sertifikat, data publik dan kebutuhan jenjang lanjutan	Menetapkan publikasi yang diperbolehkan dan perluasan profil masa depan
Q14	Sponsor, praktik, magang dan pihak mitra	Tidak menambah akun atau akses mitra sebelum kebutuhan disetujui

Status pembahasan

Seluruh keputusan pada tabel masih memerlukan konfirmasi pemilik proses; dokumen ini tidak mencatatnya sebagai persetujuan Vaneta. Paket profil awal disusun setelah peran nyata dipetakan. Tidak perlu mengaktifkan semua peran atau izin khusus bila tugas pilot tidak membutuhkannya.

Kebijakan belum diputuskan tidak boleh berubah menjadi izin luas sebagai jalan pintas. Gunakan lingkup minimum yang disepakati untuk alur yang siap, sementara tindakan yang memerlukan keputusan tersebut tetap belum aktif. Catat pengecualian dalam versi kebijakan agar penguji dapat mereproduksi keputusan akses.

20 Sumber dan pemeliharaan dokumen

Dokumen internal sebagai sumber kebutuhan

- D1 KSMA PRD v1.0: 32 persyaratan fungsional, 10 NFR, 36 skenario penerimaan serta Q01 sampai Q14.
- D2 KSMA Arsitektur Sistem dan Model Data v1.0: pemisahan identitas, lingkup lembaga, transaksi, pekerjaan latar, berkas dan pencabutan.
- D3 KSMA Backlog MVP dan Rencana Implementasi Pilot v1.0: 50 paket kerja dan dependensi pelaksanaan.
- D4 KSMA Alur Pengguna dan Blueprint Prototipe v1.0: referensi perilaku alur; belum merupakan hasil validasi pengguna atau desain visual yang diterima.

Referensi teknis primer

R1 OWASP Authorization Cheat Sheet. Diperiksa 19 Oktober 2026. Digunakan untuk prinsip hak minimum, penolakan secara bawaan, pemeriksaan per permintaan, serta pertimbangan atribut dan hubungan.

https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

R2 OWASP Multi Tenant Security Cheat Sheet. Diperiksa 19 Oktober 2026. Digunakan untuk memeriksa rancangan batas pelanggan dan perlunya membawa konteks pelanggan ke lapisan data, cache, berkas serta pekerjaan latar.

https://cheatsheetseries.owasp.org/cheatsheets/Multi_Tenant_Security_Cheat_Sheet.html

Daftar peran, 73 tindakan, kombinasi izin, keputusan pemulihan dan skenario uji pada dokumen ini adalah usulan khusus KSMA berdasarkan sumber kebutuhan internal. Referensi OWASP tidak menyatakan bahwa daftar tersebut merupakan kebijakan Vaneta, sertifikasi keamanan atau bukti kepatuhan hukum.

Pemilik dan perubahan

Pemilik dokumen produk yang diusulkan adalah tim Kitapandu; penetapan kebijakan operasional berada pada pihak berwenang di Vaneta. Nama individu, penanggung jawab persetujuan dan jadwal peninjauan belum ditetapkan.

Setiap perubahan mencatat alasan, tindakan yang berubah, lingkup, versi profil, kebutuhan migrasi grant serta skenario uji terdampak. Dokumentasi, register izin dan implementasi perlu diperbarui bersama. Grant yang mengacu versi lama tidak boleh diam diam menerima hak baru tanpa mekanisme perubahan yang disetujui.

Dokumen lanjutan yang disarankan adalah Kamus Data dan Aturan Validasi KSMA, diikuti spesifikasi API setelah keputusan teknologi yang diperlukan ditetapkan. Keduanya memakai batas kolom, status objek dan pemeriksaan izin dari dokumen ini.